ECEWS TalentScreen

AI-assisted recruitment and shortlisting system — system design

Item	Detail
Organisation	Excellence Community Education Welfare Scheme (ECEWS)
Document	System design and architecture, version 1.0
Prepared for	Olanrewaju (Lanre) Agunloye, Senior IT Officer, ACE-5 Programme
Date	7 October 2026
Codebase	ecews-talentscreen (NestJS API + worker, React web, PostgreSQL, Docker / Kubernetes)
Status	Implemented and tested end to end outside Docker; Docker images to be built on first deployment

Guiding principle. TalentScreen is a decision-support system. It never makes a hiring decision. Every recommendation is evidence-based, explainable and reviewed by authorised ECEWS staff, and every human override is recorded with its reason.

Contents

Right-click the table and choose Update Field if page numbers are missing.

1. Purpose and scope

TalentScreen screens job applicants objectively and consistently against hiring criteria that HR and hiring managers define per vacancy. It parses CVs, matches them to mandatory and preferred requirements, computes a weighted score, recommends Shortlist, Consider, Hold or Reject, ranks the pool and explains each result with quoted evidence from the CV.

The system covers the full recruitment loop that follows a CV:

- Vacancy creation, hiring requests raised by managers and approval by HR.
- Single and bulk CV upload (PDF, DOCX, TXT) with automatic evaluation.
- Ranking, shortlisting, side-by-side comparison and human override.
- Interview scheduling, panel scoring and hiring recommendations.
- Reports with PDF, Excel and CSV export; audit logs; notifications.
- User, role and permission management with fine-grained, editable RBAC.

1.1 Design decisions at a glance

Decision	Choice	Why
Backend	NestJS (Node.js 22, TypeScript)	Listed in the specification; modular, typed, testable; one image serves API, worker and migrations.
Frontend	React 18 + Vite, served by nginx	Listed in the specification; small bundle (77 kB gzipped); nginx also proxies /api and sets security headers.
Database	PostgreSQL 16	Listed; JSONB for requirements and evaluations; triggers make the audit log append-only; also hosts the job queue.
Job queue	pg-boss on PostgreSQL	Durable retries without a separate broker. Replaceable by Azure Service Bus behind one class.
File storage	MinIO / S3 / Azure Blob / local	Pluggable driver; files are encrypted by the application before they reach any backend.
Search	PostgreSQL trigram + full-text	Covers candidate and skill search at ECEWS volumes without running Elasticsearch (see section 11).
AI engine	Rules engine always; Azure OpenAI or OpenAI optional	Scores stay deterministic and explainable; the model only checks evidence the rules could not find, and every claim must quote the CV.
Authentication	Local accounts + Microsoft Entra ID (OIDC)	Entra app roles map directly to TalentScreen roles; JWT access tokens with rotating refresh tokens.
Deployment	Docker Compose; Kubernetes (AKS) manifests; GitHub Actions	Single-host Docker for a first deployment, AKS reference for scale-out.

2. Architecture

TalentScreen is a three-tier, container-based system. The browser talks only to the web container, which serves the React application and forwards /api requests to the API. The API and the background worker are the same image run with different commands, so they share one codebase and one set of migrations. All state lives in PostgreSQL and object storage, so every application container is stateless and can be scaled horizontally.

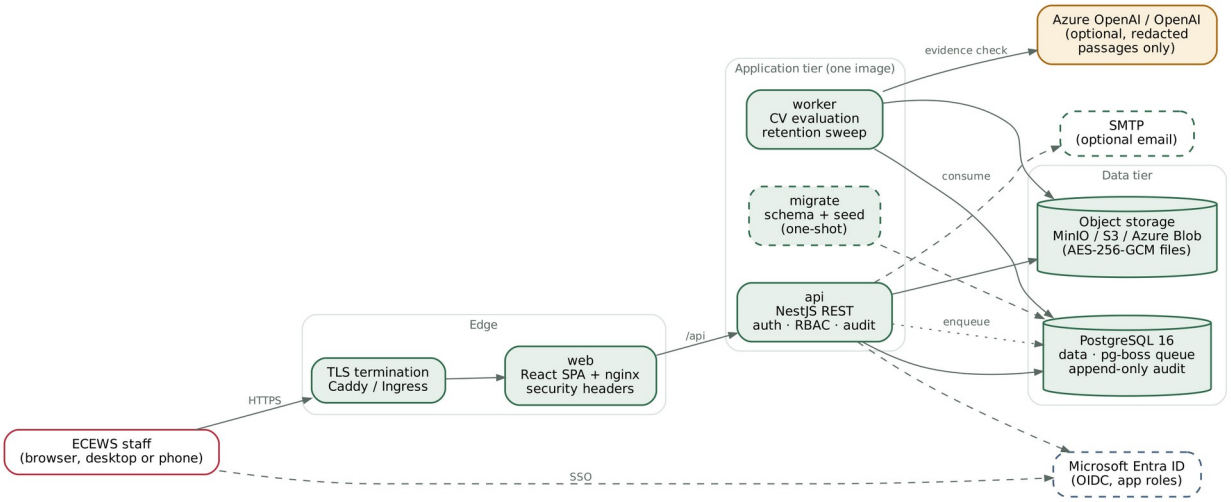


Figure 1. Containers, data stores and external services

Component	Responsibility	Scaling
web (nginx)	Serves the SPA; reverse-proxies /api; CSP, frame, referrer and content-type headers; 60 MB upload limit	Stateless; any number of replicas
api (NestJS)	REST endpoints, authentication, RBAC guard, row-level scoping, CV ingestion, exports, audit	Stateless; 2+ replicas behind the Service
worker	Consumes evaluation jobs; recovers stuck jobs every 5 minutes; nightly retention sweep at 02:30 WAT	Horizontal (pg-boss gives each job to one worker); HPA on CPU
migrate	Applies SQL migrations under an advisory lock; seeds permissions, roles, departments, defaults; creates first admin	One-shot per release
PostgreSQL	All relational data, JSONB documents, job queue, audit chain	Managed service in production (Azure Database for PostgreSQL Flexible Server)
Object storage	Original CV files, encrypted with AES-256-GCM before upload	MinIO in Compose; Azure Blob or S3 in production
AI provider	Optional evidence check and short narrative	External; called only from the worker

2.1 Request flow

1. The user signs in with a password or through Microsoft Entra ID. The API returns a 15-minute access token (kept in memory, never in browser storage) and sets a rotating refresh token in an httpOnly, SameSite=Strict cookie scoped to /api/auth.
2. Every request passes the global guard: it validates the token, reloads the user's role and permissions from the database (so suspensions and role changes take effect immediately) and enforces the route's permission.

3. Queries add a row-level scope: assigned vacancies for recruiters and hiring managers, assigned candidates for panel members, aggregates only for viewers.
4. An upload is validated, text-extracted, de-duplicated, encrypted, stored and queued in one transaction; the worker evaluates it within seconds and notifies the uploader and the vacancy team when a batch finishes.

3. Evaluation engine

The engine turns a CV and a vacancy into a score, a recommendation and an explanation. It is built so that every number on screen can be traced back to a line in the CV and a configured weight.

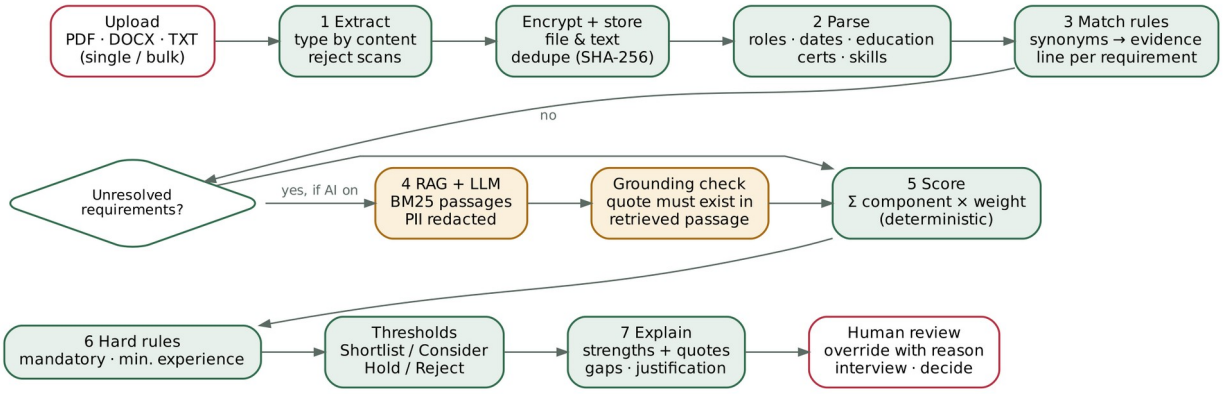


Figure 2. Evaluation pipeline

3.1 Stages

Stage	What happens	Safeguards
1 Extract	pdf.js (PDF), mammoth (DOCX) or UTF-8 (TXT); whitespace normalised	Type checked by file signature, not the browser's claim; image-only PDFs rejected with an OCR hint; 10 MB per file, 50 files per batch
Store	Original file and extracted text encrypted (AES-256-GCM); contact details encrypted; SHA-256 of the file stored	Duplicate CVs on the same vacancy are refused
2 Parse	Name, contacts, sections, roles with dates (month names, numeric months, “Present”), education level, certifications, skills, languages, memberships, awards, publications, projects	Overlapping jobs merged so experience is never double-counted; unreadable dates flagged as a gap
3 Match	Each requirement expanded through a synonym dictionary (e.g. “Entra ID” = “Azure AD”; “AZ-104” = “Azure Administrator”) and searched with word-boundary rules	The matching CV line is kept as evidence; short terms must match whole words (“LAN” never matches “language”)
4 RAG + LLM (optional)	For requirements still unmet, the top three CV passages are retrieved by BM25 and sent with the requirement to Azure OpenAI or OpenAI	Name, email, phone and LinkedIn removed first; model must quote verbatim; quote must exist in a passage retrieved for that requirement; failures discarded and stored for audit; AI matches labelled amber and flagged “confirm”
5 Score	Six component scores combined with the configured weights	Always computed in code, never by the model
6 Recommend	Hard rules, then thresholds	Rules and thresholds configurable; every rule failure stated in plain words
7 Explain	Strengths with quoted evidence, gaps, justification, optional narrative	Narrative is written only from the computed facts; it cannot add claims

3.2 Scoring model

Overall score = Σ (component score × weight) ÷ Σ weights, rounded. Default weights follow the specification:

Component	Default weight	How the component score (0–100) is computed
Qualifications	20%	70 if the highest level meets the minimum, +30 if the field of study matches; below the minimum scales proportionally; +10 for any preferred qualification found
Technical skills	30%	Share of required technical skills with evidence
Relevant experience	30%	100 at or above preferred years; 70–100 between minimum and preferred; proportional below the minimum. “Relevant” = roles that mention two or more of the vacancy's skills or share a title keyword (configurable to total experience)
Certifications	10%	Share of required certifications evidenced (100 if none required)
Preferred skills	5%	Share of soft skills, preferred skills, industry experience and nice-to-haves evidenced
Career progression	5%	Seniority of latest role versus first role, plus average tenure (stability)

3.3 Recommendation logic

Order	Rule	Default
1	Any mandatory requirement without evidence → Reject (reason stated)	On
2	Relevant experience below the vacancy minimum → Reject (reason stated)	On
3	Score ≥ Shortlist threshold → Shortlist	85
4	Score ≥ Consider threshold → Consider	65
5	Score ≥ Hold threshold → Hold; otherwise Reject	50

Fairness. Name, gender, age, photo, religion, marital status and state of origin are not inputs to any rule. A unit test adds these attributes to a CV and asserts the score is unchanged. With AI enabled, the candidate's name and contact details are removed before any text leaves the server.

3.4 Worked example (demo data)

Candidate	Score	Recommendation	Why
Chidinma Okafor	97	Shortlist	All 8 required skills evidenced, 3 of 4 certifications, 10.4 years relevant experience, Master's in a relevant field
Adaeze Nnamdi	88	Shortlist	All required skills, AZ-104; missing MS-102, CCNA and ITIL
Ibrahim Musa	82	Consider	Strong networking and Azure; no evidence of Intune or Defender
Grace Udoh	75	Reject	Mandatory requirement “Azure” not evidenced, despite 9.7 years relevant experience; HR may override with a reason
Tolu Bankole	49	Reject	2.8 years relevant experience against a 5-year minimum; Azure missing

4. Data model

The schema is a single SQL migration (apps/api/migrations/001_init.sql). Requirements, component scores, evidence and profiles are JSONB, so the scoring model can evolve without schema changes. Evaluations are versioned: re-scoring creates a new version and keeps the history.

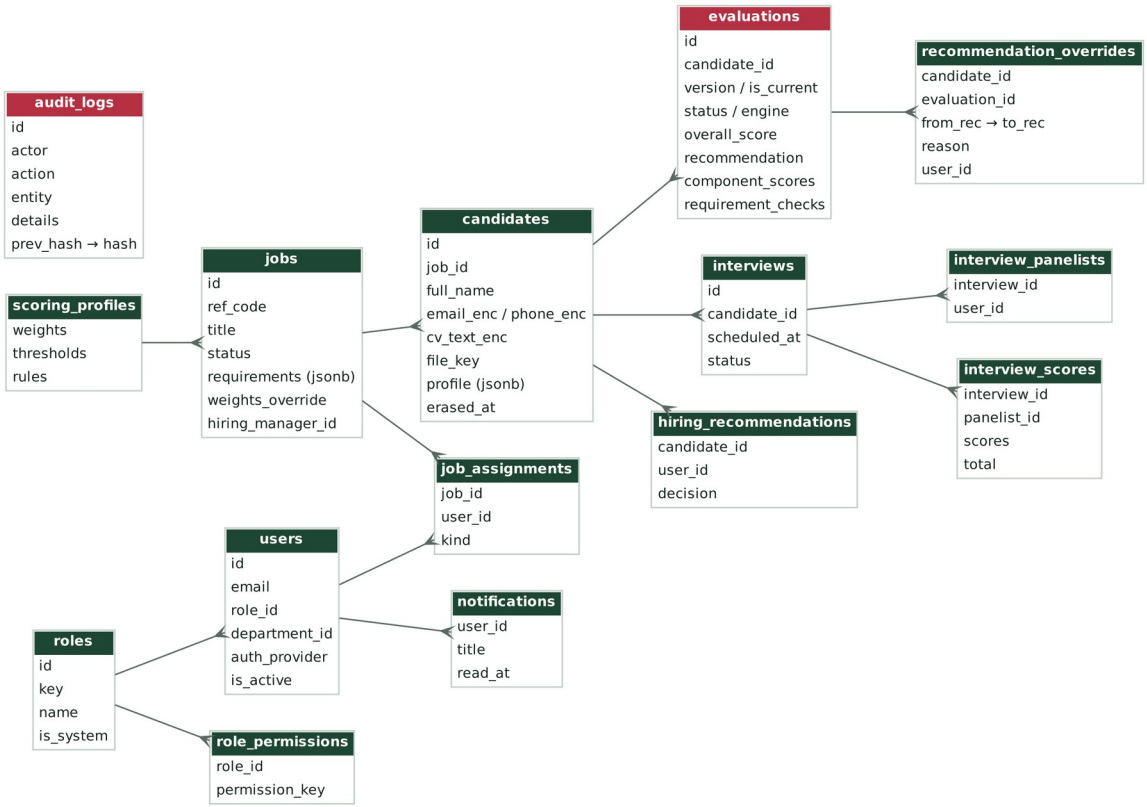


Figure 3. Main tables and relationships (crimson headers: evaluation results and the audit trail)

Table	Purpose	Notes
users, roles, permissions, role_permissions	Accounts and fine-grained RBAC	Permissions catalogue seeded; grants editable at runtime; at least one active Super Administrator enforced
refresh_tokens	Rotating refresh sessions	Stored as SHA-256 hashes; reuse of a revoked token ends every session for that user
organisations, departments	Organisational structure	Seeded with ECEWS and five departments
jobs, job_assignments	Vacancies, hiring requests, assigned recruiters	Status: requested → open → closed / filled (or rejected)
candidates	One application per CV per vacancy	email_enc, phone_enc, cv_text_enc encrypted; erased_at for data-protection erasure
evaluations	Versioned results	One current version per candidate (partial unique index); requirement_checks keep evidence and source (rules / llm)
recommendation_overrides	Human decisions on AI recommendations	Reason of at least 10 characters enforced by a CHECK constraint
interviews, interview_panelists, interview_scores, hiring_recommendations	Interview loop	One score per panellist per interview

Table	Purpose	Notes
scoring_profiles, ai_settings	Configuration	Changed in the app, audited before/after
notifications	Notification centre	Optional email copy over SMTP
audit_logs	Append-only, hash-chained audit trail	Triggers reject UPDATE, DELETE and TRUNCATE; each row hashes the previous row

5. Role-based access control

Access is enforced twice: a route-level permission check, then a row-level scope in every query. Permissions are data, not code, so a Super Administrator can add a role (for example “Programme Director”) or adjust a grant on the Roles & permissions screen. Changes apply on the user's next request.

Permission	Super Admin	HR Admin	Hiring Mgr	Recruiter	Panel	Viewer
Manage users, roles, organisations	✓					
Configure scoring and AI	✓					
View / export audit log	✓					
Create, edit, approve vacancies	✓	✓				
Raise hiring requests	✓		✓			
Upload CVs	✓	✓		✓		
View candidates	all	all	assigned	assigned	interviewed only	
View evaluations and rankings	✓	✓	✓	✓		
Override recommendations	✓	✓				
Update applicant status	✓	all moves		early stages		
Schedule interviews	✓	✓		✓		
Score interviews	✓		✓		✓	
Hiring recommendation	✓		✓			
View reports	✓	✓	✓			✓ (aggregate)
Export reports	✓	✓				
Erase candidate data	✓	✓				

Panel members never see candidate contact details or the CV file, only the evaluation needed to interview. Recruiters can move candidates through early stages (new, screening, interview, withdrawn); only roles with workflow management can shortlist, offer, hire or reject.

6. Security and data protection

Area	Control
Transport	HTTPS via Caddy (automatic certificates) or Kubernetes ingress with cert-manager; HSTS; Secure cookies when PUBLIC_URL is https
Encryption at rest	Application-level AES-256-GCM for CV files, CV text, candidate email and phone, independent of disk or storage-account encryption. Key in DATA_ENCRYPTION_KEY (Key Vault in production)
Authentication	bcrypt (cost 12) passwords; 12-character policy; lockout after 5 failures for 15 minutes; forced change of temporary passwords; OIDC with PKCE, state and nonce for Entra ID
Sessions	15-minute HS256 access tokens held in memory; 7-day refresh tokens, hashed, rotated on every use, reuse detection; suspension revokes all sessions
Authorisation	Global guard + per-route permissions + row-level SQL scopes; permissions reloaded on every request
Input handling	DTO validation with whitelisting; parameterised SQL only; file type by signature; upload size and count limits; rate limiting (10 sign-in attempts per minute)
HTTP hardening	helmet on the API; nginx CSP, X-Frame-Options DENY, nosniff, referrer and permissions policies
Audit	Every sign-in (and failure), view of candidate data, upload, evaluation, override, status change, interview, export and configuration change. Append-only by trigger and hash-chained; integrity check in the UI and at /api/audit/verify
AI data minimisation	Only unresolved requirements and their retrieved passages are sent; name, email, phone and LinkedIn are redacted; provider can be switched off entirely
Containers	Non-root users; read-only root filesystem and dropped capabilities in Kubernetes; network policy limits API ingress to the web pods

6.1 Data protection (NDPA 2023 and GDPR)

- **Lawful, limited processing:** only CV content relevant to the vacancy is scored; protected attributes are ignored.
- **Human involvement:** no automated decision has legal effect; every recommendation is reviewed and overrides are recorded with reasons.
- **Transparency:** every score is explained with evidence, suitable for answering a candidate's request for an explanation.
- **Erasure:** a single action removes the file, text, contact details and quoted evidence while keeping anonymised scores for reporting.
- **Retention:** a nightly job erases personal data on closed or filled vacancies after a configurable period (default 24 months); hired candidates are kept.
- **Accountability:** the audit trail records who accessed which candidate and when.

7. API

A RESTful JSON API under /api, documented with OpenAPI at /api/docs. All routes need a Bearer token except sign-in, refresh, provider discovery and health.

Area	Endpoints
Auth	POST /auth/login, /auth/refresh, /auth/logout, /auth/change-password · GET /auth/me, /auth/providers, /auth/oidc/login, /auth/oidc/callback
Vacancies	GET/POST /jobs · GET/PUT /jobs/:id · POST /jobs/:id/decision · PATCH /jobs/:id/status · POST /jobs/:id/rescore
Candidates	POST /jobs/:id/candidates (multipart, bulk) · POST /jobs/:id/candidates/text · GET /candidates · GET /candidates/:id · GET /candidates/:id/file · PATCH /candidates/:id/status · POST /candidates/:id/evaluate · POST/DELETE /candidates/:id/override · POST /candidates/:id/erase
Ranking	GET /jobs/:id/ranking · GET /jobs/:id/compare?ids=…
Interviews	GET/POST /interviews · PATCH /interviews/:id · POST /interviews/:id/scores · POST /candidates/:id/recommendations
Reports	GET /dashboard · GET /reports/summary · GET /reports/export?format=pdf|xlsx|csv
Administration	GET/POST/PATCH /users · POST /users/:id/reset-password · GET /permissions · GET/POST/PUT/DELETE /roles · GET/POST /organisations, /departments · GET/PUT /settings/scoring/default · GET/PUT /settings/ai
Audit and notifications	GET /audit · GET /audit/verify · GET /audit/export · GET /notifications · POST /notifications/read
Health	GET /health

8. Deployment

8.1 Docker Compose (single host)

docker-compose.yml runs six services: postgres, minio, migrate, api, worker and web. The migrate service must complete before the API and worker start; the web container waits for the API health check. Data persists in named volumes (pgdata, miniodata, uploads).

Step	Command
1. Configure	cp .env.example .env && ./scripts/init-env.sh
2. Start	docker compose up -d --build
3. First admin	docker compose logs migrate (one-time password), or set BOOTSTRAP_ADMIN_PASSWORD
4. Verify	python3 scripts/smoke_test.py --base http://localhost:8080 --admin-email … --admin-password …
HTTPS	docker compose -f docker-compose.yml -f docker-compose.tls.yml up -d (Caddy, Let's Encrypt)
Scale evaluation	WORKER_REPLICAS=3 docker compose up -d worker

8.2 Azure Kubernetes Service (reference)

- Images built and pushed to GitHub Container Registry by the CI workflow on every merge to main.
- Azure Database for PostgreSQL Flexible Server (allow-list pgcrypto and pg_trgm), Azure Blob Storage, Azure OpenAI, Entra ID.
- Secrets from Azure Key Vault through the Secrets Store CSI driver; configuration in a ConfigMap.
- Migrate Job per release, then api (2 replicas), worker (HPA 1–6), web (2 replicas), ingress with cert-manager, network policy.

8.3 Configuration

All infrastructure settings are environment variables documented in .env.example. Business settings (weights, thresholds, hard rules, AI provider, evidence, redaction, retention) are edited in the application by authorised roles and audited.

9. Requirements traceability

Requirement (from the brief)	How it is met
CV parsing of all listed fields	Parser extracts name, contacts, summary, employment history, titles, responsibilities, skills, education, certifications, memberships, projects, awards, publications, languages, total and relevant years
Qualification, skills, experience matching	Requirement checks per category with evidence; relevant-experience model; career progression and stability
Reject on failed minimum experience unless configured	Hard rule, switchable in Scoring & AI
Configurable weighted scoring without code changes	Organisation default and per-vacancy weights in the UI; thresholds and rules too; changes re-score automatically
Four-way recommendation with evidence	Shortlist / Consider / Hold / Reject with justification and quoted CV lines
Ranking with the listed columns	Rank, name, score, years, qualification %, skills %, recommendation, key strengths, key gaps
Per-candidate output format	Candidate summary, qualification assessment, strengths, gaps, final recommendation on the assessment page
Six roles with listed capabilities	Seeded roles and permissions; editable matrix; row-level scoping
All listed front-end screens	Implemented, including candidate comparison, notification centre, audit log and exports
Single and bulk upload; concurrent campaigns	Multipart bulk upload; unlimited open vacancies with independent criteria
Complete audit logs	Append-only, hash-chained, exportable
Encryption at rest and in transit	AES-256-GCM application encryption; TLS at the edge
Responsive web app; REST; OAuth2/JWT	Responsive React UI (tested at phone width); REST + OpenAPI; JWT and OIDC
High availability; logging and monitoring	Stateless replicas; health checks and probes; structured logs; durable queue with retries and stuck-job recovery
Explainable AI with human review	Deterministic scoring; grounded AI evidence; override workflow

10. Verification

The following was run against the code in this repository:

Test	Result
Engine unit tests (vitest): parsing, date maths, synonyms, scoring, hard rules, configurable rules, protected-attribute invariance, model-evidence acceptance, retrieval, redaction	13 of 13 passed
End-to-end smoke test against the production build behind the real nginx configuration, on a freshly migrated database: sign-in, wrong-password rejection, RBAC denials for each role, hiring request and approval, bulk upload (PDF, DOCX, rejected PNG), duplicate detection, queued evaluation by the worker, ranking, override, interview scheduling, panel visibility limits, scoring, hiring recommendation, PDF/XLSX/CSV export, audit coverage and hash-chain verification	45 of 45 checks passed
AI path against a mock OpenAI-compatible server	Requests sent with redacted passages; 7 fabricated quotes discarded; narrative stored; provider failure falls back to rules
Storage drivers	S3 (mock S3 server) and Azure Blob (Azurite): encrypted round trip, bucket/container creation and delete verified; local driver used in the end-to-end tests
Browser checks (Chromium)	Desktop and 390 px phone layouts; session survives reload; sign-out clears the session; no script errors
Docker Compose files	Validated with docker compose config

> **Not yet run here:** building the Docker images and starting the Compose stack (the build environment could not download base images), a live call to Azure OpenAI, and a live Entra ID sign-in. The image build steps were replayed outside Docker with the same commands and passed. Run the smoke test after the first docker compose up to confirm on your host.

11. Limitations and roadmap

Area	Current state	Next step
Scanned CVs	Rejected with a message	Add OCR (Azure AI Document Intelligence) in the worker
Search	PostgreSQL trigram search over names, skills and titles	Add Elasticsearch / Azure AI Search when CV volume or semantic search needs it
AI evidence	Grounded quotes, but a real line can still be judged relevant wrongly	Keep amber “confirm” flags; sample-audit AI matches; tune prompts per role family
Synonyms	Curated dictionary for IT, M&E, finance and health	Extend from override reasons; per-department dictionaries
Calendar	Interviews stored in-app with notifications	Create Outlook/Teams meetings through Microsoft Graph
Candidate portal	Internal tool only	Public application form feeding the same pipeline
Bias monitoring	Protected attributes excluded by design	Periodic adverse-impact report by HR (requires voluntary, separately stored demographic data)